

 PLANO ESTRATÉGICO DE SEGURANÇA

Proposta de Segurança da Informação

Arquitetura de Defesa em Profundidade para Software House SaaS

 Grupo D | SSI

 ETEC - Segurança da Informação

 Ambiente Multi-Tenant

Cenário Atual & Desafio de Segurança

Contexto Operacional

Software House SaaS com 80 colaboradores, plataforma multi-tenant, integração via APIs e infraestrutura 100% em nuvem.

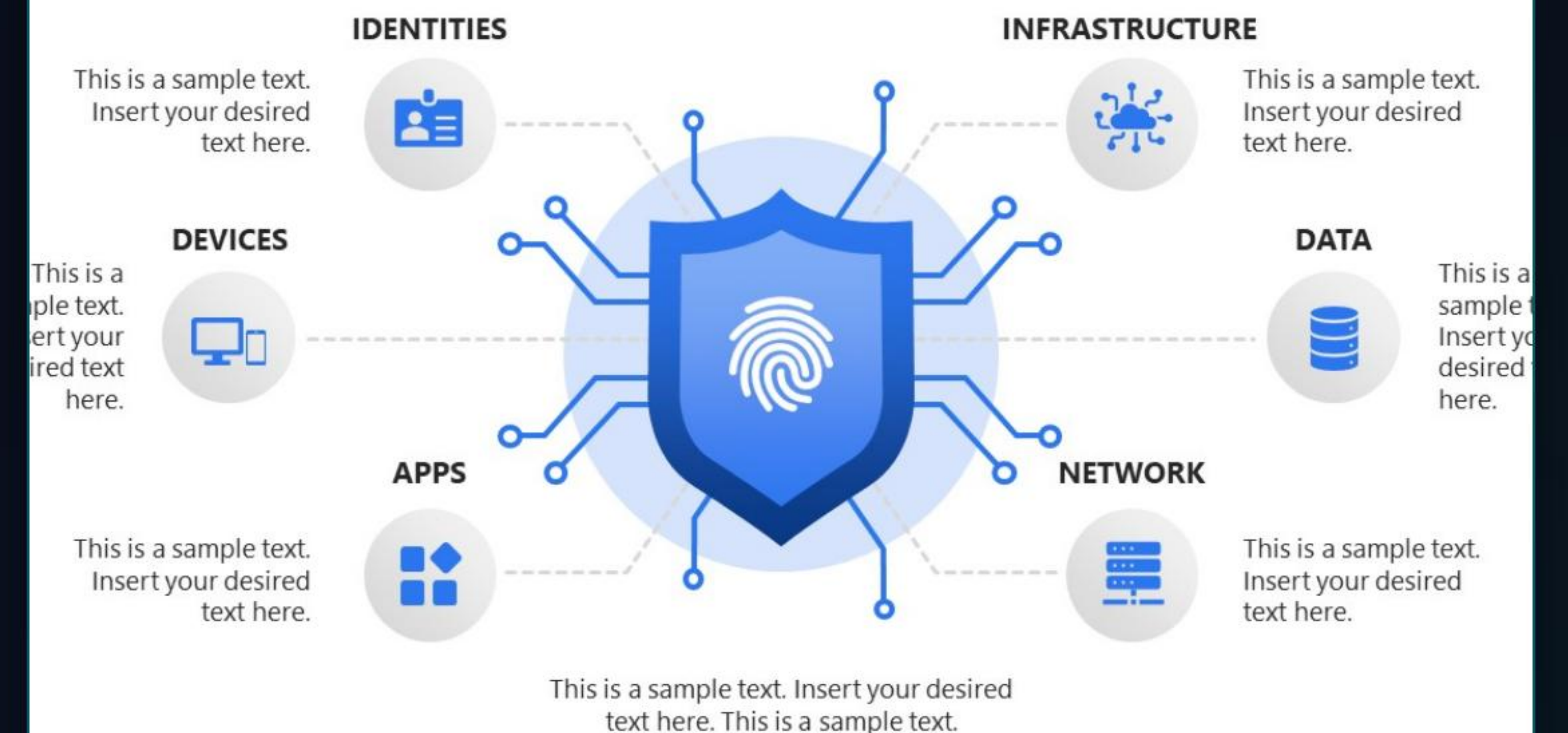
Ativos Críticos a Proteger

Banco de dados de clientes, propriedade intelectual (código-fonte), credenciais de acesso e servidores de produção.

Conceito Chave: Defesa em Profundidade

Múltiplas camadas de proteção sobrepostas. Se uma barreira falhar, as subseqüentes impedem a invasão do atacante.

Item Cyber Security Diagram PowerPoint Template



Proteção de Perímetro e Rede (Arquitetura)



Firewall NGFW

Firewall de Nova Geração com inspeção profunda de pacotes (DPI), regras de bloqueio explícitas e fechamento automático de portas vulneráveis.



Monitoramento IDS / IPS

IDS para detecção de anomalias e IPS em linha para bloqueio automatizado de ameaças ativas com análise heurística.



Zona Desmilitarizada (DMZ)

Isolamento estrito dos servidores Web e APIs (portas 80 e 443). Zonas públicas sem armazenamento direto de dados sensíveis.



Segmentação por VLANs

VLAN 10: Dev & Código | **VLAN 20:** Produção
VLAN 30: Admin / Financeiro | **VLAN 40:** Visitantes

Proteção de Endpoints e Gestão de Identidade

EDR Avançado

- Detecção e resposta em tempo real em 100% das máquinas.
- Análise comportamental contínua 24/7 contra malwares e zero-days.
- Isolamento remoto automatizado e integração com SIEM.

Autenticação MFA

- MFA obrigatório para todos os colaboradores e acessos SaaS.
- Exigência de Senha + Token App + Biometria para Administradores.
- Bloqueio automático após 5 tentativas incorretas.

Menor Privilégio

- Princípio do Menor Privilégio (PoLP) baseado estritamente em função.
- Proibição de privilégios de admin em estações de trabalho.
- Revisão e auditoria trimestral de acessos.

Proteção de Dados, Backups & APIs

Criptografia Ativa

Repouso (At Rest): Padrão AES-256 para bancos de dados e discos.

Trânsito (In Transit): Protocolo TLS 1.3 em todas as conexões.

Gestão de chaves em cofre de senhas dedicado (KMS) com DLP ativo.

Backup 3-2-1-1-0

3 Cópias de dados mantidas.

2 Mídias de armazenamento distintas.

1 Cópia em ambiente Offsite (Nuvem).

1 Cópia Imutável / Offline (Anti-Ransomware).

0 Erros verificados em testes mensais de restauração.

Segurança de APIs

- Autenticação via **OAuth 2.0** e validação de requisições.

- **WAF** contra ataques OWASP (SQLi, XSS, CSRF).

- Rate Limiting configurado por IP e cliente.

- Testes de Intrusão (Pentests) semestrais.

Resposta a Incidentes & Investimento Anual



Camada de Proteção	Participação (%)	Investimento Estimado (Anual)
Firewall NGFW & Perímetro de Rede	25%	R\$ 50.000,00
EDR (Endpoint Detection & Response)	20%	R\$ 40.000,00
Gestão de Identidade, MFA & Acessos	15%	R\$ 30.000,00
Backup Imutável & Criptografia KMS	15%	R\$ 30.000,00
Demais Camadas (IDS/IPS, WAF, Treinamentos)	25%	R\$ 50.000,00
INVESTIMENTO TOTAL ESTIMADO	100%	R\$ 200.000,00 (Faixa: R\$ 180k – R\$ 250k)

🚩 Conclusão e Frameworks de Referência

🛡️ Resiliência Operacional

A abordagem em camadas elimina pontos únicos de falha, reduz o tempo de inatividade e garante continuidade de negócios.

🤝 Confiança do Cliente SaaS

A proteção robusta do ambiente multi-tenant assegura a integridade do código-fonte e o sigilo de dados de múltiplos clientes.

⚖️ Conformidade Legal (LGPD)

Atende rigorosamente aos requerimentos da LGPD e padrões internacionais de proteção e auditoria de dados.

📖 Referências Normativas

OWASP Top 10:2025 • NIST Cybersecurity Framework 2.0 • NIST SP 800-207 (Zero Trust) • CSA SaaS Security 2026 • ETEC SSI



Image Sources



<https://slidemodel.com/wp-content/uploads/23181-02-6-item-cyber-security-diagram-powerpoint-template-16x9-1.jpg>

Source: slidemodel.com



https://securityjournaluk.com/wp-content/uploads/2026/08/Digital-Network-Architecture_-Strengthening-Enterprise-Security-and-Network-Resilience-1.webp

Source: securityjournaluk.com